

**CWE AI Working Group
Meeting Minutes
January 31, 2025**

Attendance

- | | | |
|---------------------------|------------------|---------------------------|
| • Monika Akbar | • Martin Hodo | • Kevin Monette |
| • Chris Coffin | • Alec Summers | • Kyle Norland |
| • Steve Christey
Coley | • Mike Simon | • Lee Szilagyi |
| • Erick Galinkin | • Raymond Pompon | • Pieter van
Wassenaer |
| | • Caroline Rocha | |

Agenda:

- Meeting Introduction
- Status Updates
- Open Discussion: Goals for 2025
- Content “Working Queue” Summary

Meeting Notes:

Meeting Introduction: Alec introduced the January 31 meeting of the AI Working Group, and outlined the agenda, which included status updates for the CWE AI WG, an open discussion focused on goals for 2025, and a review of existing content in the CDR, prioritizing and publishing modifications and new entries.

Status Updates: Alec announced a new meeting cadence where meetings for the CWE AI WG will alternate between focusing on new weakness development and modifications to existing weaknesses. Alec emphasized that while the focus areas are defined, there is flexibility to address other topics as needed during the meetings. New meeting invitations would be sent out to reflect the topics.

- **New Co-Chair:** Alec announced that Eric Galinkin, current chair of the CVE AI WG, has stepped forward as a new co-chair for the group, and there is a

Commented [SC1]: Sentence was originally incomplete.
Feel free to copyedit.

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CVE Program prior to publishing. Please report any inaccuracies or other issues to the CVE Program.

call for an additional co-chair to help manage the workload, who could focus on either weakness development or modifications.

- **Co-Chair Volunteers:** Two members expressed a desire to step up as co-chairs if needed, and an ad hoc meeting will be set up to discuss responsibilities and finalize the choice of co-chair.
- **New Member Introduction:** Kevin Monette introduced himself as a new member, sharing his background in cybersecurity and interest in AI.
- **Next CWE Release:** Alec mentioned the next content release is planned for late March 2025, possibly extending into early April, focusing on macro-level usability improvements to the CWE website.
 - **Usability Improvements:** The release will focus on macro-level usability improvements to the CWE website, including simplifying navigation and streamlining guidance. Alec encouraged feedback from the WG members.
 - **Release Timeline and Workload:** Steve pointed out that based on experience, the group needs at least a month of dedicated work to produce new entries. Steve noted that the time available is limited for creating new content.
 - **Subgroup Formation:** Alec discussed the bifurcation of the WG into two subgroups: proposed Subgroup 1 would focus on improving existing CWE content relevant to AI systems. Proposed Subgroup 2 would focus on developing new CWE entries to cover AI-related gaps in the CWE corpus. Alec mentioned that the formation of the new subgroups was meant to focus and prioritize the CWE AI effort.
 - **Participation:** Members were encouraged to volunteer for their preferred areas, with the option to contribute to both subgroups if desired. Leads would be identified for both subgroups.
 - **Cadence:** The new operational cadence will involve updating meeting invitations per email to clearly label the focus of each meeting, ensuring members are aware of the agenda.

Commented [SC2]: Avoid the names here - just say "Two members". Rationale: if somebody doesn't get chosen then we don't want to make them look bad.

Status "Working Queue" Summary

New Entry Development: Steve discussed upcoming content work, including proposals for new CWE entries and modifications to existing ones. He stressed the importance of prioritizing the work, which would be guided by the subgroups, before introducing the first of three new proposed CWE entries.

- **“Bias in AI Models” (Kurt Seifried) – ES2402-38e20ce6:** The group discussed a proposal on bias in AI models, with concerns raised about distinguishing between security weaknesses and functional issues.
 - The group discussed whether bias in AI models should be considered a weakness within the CWE framework. Erick raised concerns about the blurred lines between security related weaknesses and artifacts in probabilistic systems, with Martin noting bias could be a model backdoor.
 - Michael agreed with the idea that bias could be considered an "induced weakness," where an attacker could exploit it, rather than being inherent to the model.
 - Lee noted that the proposal on bias in AI models seems more aligned with "trustworthy and responsible AI" rather than security, emphasizing that it focuses on the inducement aspect.
 - Monika pointed out that bias is too broad to be a single weakness.
 - Steve highlighted the role of attackers in exploiting weaknesses and mentioned adversarial examples, especially in facial recognition.
 - Steve noted unanimous agreement that this was not a clear weakness, and that he would capture the discussion in the submission.
 - Martin proposed running thought experiments on whether a product with a bias-prone model could be considered a weakness, especially if influenced by an attacker.
 - Erick suggested this might already be covered under adversarial examples.
 - Steve mentioned face recognition systems, highlighting the potential vulnerability if used for authentication.
- **“Improper Tuning of Model Control Parameters” (Lily Wong) - ES2406-9e5cf10:** The group discussed improper hyperparameter tuning in AI models, particularly the impact of high temperature settings causing hallucinations. There was debate over whether this is a security weakness or a functional issue. Some members saw it as a functional concern, while others highlighted security risks, such as revealing sensitive information or bypassing guardrails.
 - Erick Galinkin offered an overview of the temperature hyperparameter, describing how low values produce deterministic outputs while higher values increase randomness—potentially leading to hallucinations. He illustrated how an elevated temperature might cause an LLM to invent non-existent packages during code suggestions, creating a potential security risk if malicious actors register those packages.

- Lee R. Szilagyi noted that Lily Wong’s proposed entry could be a valuable addition to CWE, especially because “hallucination” frequently appears in LLM discussions.
 - Martin Hodo, however, questioned whether hallucinations always represent a security risk or simply a functional concern—highlighting the context dependency in determining whether a misconfiguration is a genuine vulnerability.
 - Erick Galinkin raised the complexity of hyperparameter optimization, acknowledging that even “perfect” settings do not guarantee the absence of hallucinations.
 - Steve suggested that CWE entries can be contextual, focusing on how certain settings create exploitable conditions.
 - Michael Simon pointed out that misconfigurations can occur in any system and are not uniquely AI-specific. He argued that if improper tuning is presented as a new CWE, it must clearly demonstrate how AI misconfiguration poses unique security risks beyond typical “bad configuration” issues.
- **“Insufficient Input Validation in Generative AI Applications” (Steve/AI WG) - ES2405-84711fc4**
 - Steve deferred discussion for this entry for another meeting, citing significant overlap with other CWEs, and the submission does not fit cleanly into the CWE repository’s hierarchical structure.
 - **Modification Work Items:** Steve outlined future content work, including ongoing submissions for new CWE entries and modifications to existing entries, with a focus on AI-related weaknesses.
 - **Adversarial Perturbation:** CWE-1039: Automated Recognition Mechanism with Inadequate Detection or Handling of Adversarial Input Perturbations, published in 2018, was identified as needing updates to reflect advancements in the field over the past six years.
 - **AI/ML Weaknesses in CWE:** He pointed out that only eight CWEs are currently tagged with AI/ML, stressing the need to capture how AI/ML technologies are still subject to many of the same vulnerabilities as traditional software.

Action Items:

- **Co-Chair Nomination:** Set up a meeting with interested members to discuss and finalize the Co-Chair roles and responsibilities. (Erick)
- **Subgroup Formation:** Update the meeting invites to clearly label each one as focusing on new entries or modifications. (Alec, Steve)